

POLÍTICA DE PRIVACIDADE E PROTECÇÃO DE DADOS

Princípios para tratamento lícito, seguro, transparente e responsável de dados pessoais

Organização	Entidade
Identificador	PPD-006
Versão	1.0 — Proposta para revisão e aprovação
Classificação	Uso interno
Proprietário	Função responsável definida pela Direcção
Aprovação	Direcção / órgão competente
Data de emissão	09 de Outubro de 2026
Revisão	Anual ou após alteração relevante

Nota de controlo: Documento de referência para validação interna. A aprovação deve ser precedida da confirmação das responsabilidades, dos requisitos legais e regulamentares aplicáveis, dos canais operacionais e dos controlos efectivamente implementados.

Histórico e controlo do documento

Versão	Data	Descrição	Responsável
1.0	09/10/2026	Emissão inicial para revisão	Função responsável

1. Objectivo e âmbito

Definir princípios e responsabilidades para o tratamento de dados pessoais efectuado pela organização, incluindo recolha, consulta, utilização, partilha, armazenamento, conservação, transferência e eliminação. Aplica-se a colaboradores, prestadores de serviços e terceiros que tratem dados pessoais por conta ou sob responsabilidade da organização.

2. Enquadramento e aplicabilidade

O tratamento deve respeitar a legislação angolana de protecção de dados e demais normas aplicáveis, bem como obrigações sectoriais, contratuais e regulamentares. Antes de cada actividade, as funções competentes devem identificar a base legal, os deveres de informação, os direitos dos titulares e eventuais obrigações de registo ou notificação perante a autoridade competente.

Referências internacionais, como os princípios de minimização, limitação da finalidade, exactidão, limitação da conservação e segurança, podem servir de boas práticas, mas não substituem a lei aplicável. A validade e a aplicação de cada requisito devem ser confirmadas por Jurídico/Compliance ou pela função de privacidade designada.

3. Princípios de tratamento

- Finalidade definida: recolher e utilizar dados para finalidades específicas, legítimas e comunicadas.
- Minimização: recolher apenas os dados adequados, pertinentes e necessários.
- Transparência: fornecer informação clara sobre finalidades, responsáveis, partilhas, conservação e direitos aplicáveis.
- Exactidão: manter dados correctos e permitir a sua actualização quando necessário.
- Conservação limitada: não guardar dados por mais tempo do que o necessário ou legalmente exigido.
- Confidencialidade e segurança: proteger os dados contra perda, alteração, divulgação ou acesso não autorizado.
- Responsabilização: demonstrar conformidade por meio de registos, decisões, avaliações e evidências.

4. Bases legais e recolha

Cada tratamento deve ter uma base legal válida identificada antes da recolha ou utilização. O consentimento, quando for a base aplicável, deve ser livre, específico, informado, inequívoco e demonstrável, e a retirada deve ser tratada conforme a lei. Não se deve presumir que o consentimento é sempre a base adequada; a relação contratual, obrigação legal ou outra base prevista na lei pode ser relevante conforme o contexto.

- Os formulários e avisos devem explicar a finalidade e evitar recolhas excessivas.
- Dados de crianças, dados sensíveis ou dados de elevado risco exigem análise reforçada e as salvaguardas legalmente exigidas.
- Dados obtidos de terceiros devem ter origem legítima e ser acompanhados da informação necessária sobre a sua proveniência e utilização.

5. Direitos dos titulares

Devem existir canais e procedimentos para receber, verificar, registar, avaliar e responder a pedidos dos titulares, incluindo direitos reconhecidos pela legislação aplicável, como acesso, rectificação, oposição, eliminação ou outros quando legalmente previstos. A identidade deve ser verificada de forma proporcional e os prazos legais devem ser controlados.

Os pedidos e decisões devem ser documentados. Quando a resposta for recusada ou limitada por obrigação legal, prevenção de fraude, defesa de direitos ou outra excepção aplicável, a decisão deve ser fundamentada e revista pelas funções competentes.

6. Partilha, terceiros e transferências

- Partilhar dados apenas com destinatários autorizados e para uma finalidade legítima, com base legal e informação adequada.

- Antes de contratar operadores ou prestadores que tratem dados, avaliar segurança, confidencialidade, subcontratação, localização, incidentes, auditoria, devolução e eliminação de dados.
- Formalizar responsabilidades e instruções de tratamento em contratos ou instrumentos adequados.
- Avaliar transferências internacionais antes de as realizar e cumprir as condições, autorizações, garantias ou notificações exigidas pela legislação aplicável.
- Não enviar dados pessoais por canais não aprovados ou a destinatários cuja identidade e necessidade não tenham sido confirmadas.

7. Segurança e privacidade desde a concepção

Os sistemas e processos devem integrar protecção de dados desde a concepção e por defeito. As medidas devem ser proporcionais ao risco e podem incluir controlo de acesso, autenticação forte, encriptação, pseudonimização, registos, segregação de ambientes, testes de segurança, cópias de segurança e limitação de exportações.

O acesso a dados pessoais deve obedecer ao menor privilégio e ser revisto periodicamente. A utilização de dados reais em desenvolvimento, testes, demonstrações ou formação deve ser evitada quando dados sintéticos ou anonimizados forem adequados.

8. Retenção e eliminação

Cada categoria de dados deve ter prazo de conservação ou critério de retenção documentado, considerando finalidade, obrigações legais, necessidades de negócio, litígios e requisitos regulatórios. No fim do prazo, os dados devem ser eliminados, anonimizados ou arquivados de forma autorizada e segura. Suspensões de eliminação por investigação ou obrigação legal devem ser documentadas.

9. Incidentes com dados pessoais

Suspeitas de perda, divulgação, acesso indevido, alteração ou destruição de dados pessoais devem ser comunicadas imediatamente pelo processo de resposta a incidentes. A equipa deve determinar categorias e volume de dados, titulares potencialmente afectados, consequências e medidas de contenção.

A função jurídica/privacidade deve avaliar sem demora os deveres, prazos e destinatários de notificação previstos na legislação aplicável. Não se deve assumir um prazo universal sem confirmar a norma aplicável ao caso concreto. As decisões de notificar ou não notificar devem ser fundamentadas e guardadas.

10. Avaliação de impacto e registos

- Manter inventário ou registo das actividades de tratamento, com finalidades, categorias de dados e titulares, destinatários, prazos de conservação e medidas de segurança, conforme aplicável.
- Avaliar previamente tratamentos novos ou alterados que possam criar riscos elevados para os titulares.
- Registar decisões sobre base legal, partilhas, transferências internacionais, pedidos de titulares e incidentes.
- Aplicar controlos reforçados a dados sensíveis, decisões automatizadas ou perfis quando aplicável.

Responsabilidades principais

Papel	Responsabilidades
Direcção competente	Garantir recursos, supervisão e responsabilização pelo cumprimento dos requisitos de privacidade.
Função de privacidade / Compliance / Jurídico	Interpretar obrigações, apoiar avaliações, direitos dos titulares, contratos e notificações.
Segurança da Informação / TI	Implementar controlos técnicos, gestão de acessos, registos, encriptação e resposta a incidentes.
Responsáveis de negócio	Definir finalidades, minimizar dados, validar bases legais com as funções competentes e manter registos.
Recursos Humanos	Assegurar tratamento adequado de dados laborais e comunicação de requisitos aos colaboradores.
Terceiros e operadores	Tratar dados apenas segundo instruções e obrigações formalizadas, notificando incidentes sem demora.

Monitorização e evidências

A função responsável deve definir a periodicidade, fonte, responsável e destinatário de reporte dos indicadores abaixo, mantendo evidências proporcionais ao risco e aos requisitos aplicáveis.

- Percentagem de actividades de tratamento inventariadas.
- Percentagem de tratamentos de maior risco avaliados antes da implementação.
- Tempo de resposta a pedidos de titulares, face aos prazos aplicáveis.
- Número de incidentes de dados pessoais e acções correctivas pendentes.
- Percentagem de contratos relevantes com cláusulas de protecção de dados revistas.
- Número de prazos de retenção vencidos sem decisão documentada.

Excepções, incumprimento e revisão

Qualquer excepção deve ser solicitada por escrito, justificada, avaliada quanto ao risco, aprovada pela autoridade competente, limitada no tempo e acompanhada de medidas compensatórias. Não pode contrariar obrigações legais ou regulamentares. O incumprimento pode resultar em medidas correctivas, restrição de acessos ou consequências disciplinares e contratuais, conduzidas pelas áreas competentes. O documento deve ser revisto pelo menos anualmente e após alterações relevantes, incidentes significativos ou mudanças legais.

Aprovação formal

Etapas	Responsável / nome	Assinatura e data
Elaboração	A preencher	A preencher
Revisão técnica / jurídica	A preencher	A preencher
Aprovação — Direcção competente	A preencher	A preencher

Entrada em vigor: após aprovação formal e divulgação aos destinatários abrangidos.